

Security Audit Report — keebforce.com

Date: June 3, 2026 **Prepared for:** Website Operator

Executive Summary

A technical security review of keebforce.com has identified **5 security vulnerabilities** in the website's source code and server configuration. Several of these issues are causing the site to be **blocked by web security tools and potentially flagged by browsers such as Google Chrome**. The issues range from critical (data exposure, mixed content) to medium severity. All findings are fixable without a full rebuild.

Finding 1 — Mixed Content: HTTP Resources on an HTTPS Site (*Critical*)

The website runs on HTTPS, but several images are being loaded via unencrypted **HTTP** links. These HTTP URLs were found hardcoded in the page's structured data (JSON-LD schema):

<http://keebforce.com/wp-content/uploads/2025/04/keebforce-transparent-logo-112.png>

<http://keebforce.com/wp-content/uploads/2025/07/customized-wooden-wrist-rest.jpg>

Why this is a problem: Mixed content allows Man-in-the-Middle (MitM) attacks on those specific resources. An attacker on the same network could intercept and replace these HTTP-loaded assets. All modern browsers and security tools flag this immediately — it is the most likely reason the site is being blocked.

Fix: In the WordPress admin panel, go to **Settings → General** and make sure both the WordPress Address and Site Address fields use https://. Then run a database search-and-replace to convert all remaining http://keebforce.com references to https://keebforce.com. Plugins like *Better Search Replace* can do this safely.

Finding 2 — Admin Email Address Publicly Exposed (*Critical*)

WordPress is exposing the administrator's email address as a public-facing author URL:

<https://keebforce.com/author/kingwait069gmail-com/>

This reveals that the admin account uses kingwait069@gmail.com as its username or user slug. This is publicly visible to anyone who views the page source and is a well-known attack vector called **User Enumeration**. It allows attackers to:

- Target the admin account with brute-force login attempts
- Launch phishing attacks specifically against the admin email
- Confirm valid usernames before attempting credential stuffing

Fix: Change the admin account's username and display name in WordPress so they do not resemble an email address. Navigate to **Users → Profile** and update the username slug. Consider using a security plugin that blocks the /author/ endpoint entirely (e.g., *Wordfence* or *iThemes Security*).

Finding 3 — Software Versions Publicly Disclosed (*High*)

Exact version numbers of installed software are visible in the page's HTML source via asset URLs:

.../woocommerce/assets/...?ver=wc-10.8.1 ← WooCommerce version

.../theme-for-woocommerce/...?ver=7.0 ← Theme version

Why this is a problem: Attackers routinely scan for version numbers and cross-reference them against public vulnerability databases (CVE, NVD, WPScan). If any known exploit exists for these exact versions, the site becomes a trivial target.

Fix: Remove version query strings from public asset URLs. This can be done by adding the following to the site's functions.php file:

```
add_filter('style_loader_src', 'remove_version_strings', 9999);

add_filter('script_loader_src', 'remove_version_strings', 9999);

function remove_version_strings($src) {
    return $src ? remove_query_arg('ver', $src) : $src;
}
```

Finding 4 — Missing HTTP Security Headers (*High*)

The server's HTTP responses are missing several critical security headers. These headers are a baseline requirement for any modern website and their absence is flagged by security scanners, browsers, and tools like Qualys SSL Labs.

Header	Status	Risk if Missing
Content-Security-Policy	Missing	Allows Cross-Site Scripting (XSS) attacks
Strict-Transport-Security (HSTS)	Missing	Enables SSL downgrade attacks
X-Frame-Options	Missing	Site can be embedded in iframes (clickjacking)
Referrer-Policy	Missing	User data leaks to third-party sites
Permissions-Policy	Missing	No restriction on camera/mic/location access

Fix: Add the following to the nginx server configuration or .htaccess file:

```
add_header Strict-Transport-Security "max-age=31536000; includeSubDomains" always;
add_header X-Frame-Options "SAMEORIGIN" always;
add_header X-Content-Type-Options "nosniff" always;
add_header Referrer-Policy "strict-origin-when-cross-origin" always;
```

```
add_header Permissions-Policy "camera=(), microphone=(), geolocation=()" always;
```

Finding 5 — Internal Server Information Leaked (*Medium*)

The following internal infrastructure headers are visible in every HTTP response from the server:

Host-Header: 8441280b0c35cbc1147f8ba998a563a7

X-Proxy-Cache-Info: DT:1

x-httpd-modphp: 1

These headers reveal details about the server's proxy setup and PHP configuration that should never be publicly visible. This information can be used by attackers to fingerprint the server infrastructure.

Fix: These headers should be stripped at the proxy or web server level. Add the following to the nginx configuration:

```
proxy_hide_header Host-Header;
```

```
proxy_hide_header X-Proxy-Cache-Info;
```

```
proxy_hide_header x-httpd-modphp;
```

Finding 6 — SSL Certificate Expiry Approaching (*Medium*)

Property	Value
Issuer	Let's Encrypt (R12)
Valid From	April 14, 2026
Expires	July 13, 2026 (~40 days remaining)
Protocol	TLS 1.3 
Verify Status	OK 

The certificate itself is currently valid and uses strong encryption (TLS 1.3). However, it expires in approximately **40 days**. Let's Encrypt certificates renew automatically via a cron job — if that automation is broken or misconfigured, the certificate will expire and all visitors will see an SSL error.

Fix: Verify that the auto-renewal cron job is active and working. Run `certbot renew --dry-run` on the server to confirm renewal is functioning correctly.

Priority Action List

Priority	Finding	Action Required
----------	---------	-----------------

Priority	Finding	Action Required
Critical	Mixed Content (HTTP images on HTTPS site)	Fix WordPress site URL settings, replace all http:// asset URLs
Critical	Admin email exposed via author URL	Change admin username slug, disable author archive endpoint
High	Software versions disclosed	Strip ?ver= parameters from asset URLs
High	Missing security headers	Add headers to nginx / .htaccess
Medium	Internal proxy headers leaked	Strip headers at proxy level
Medium	SSL certificate expires in ~40 days	Verify certbot auto-renewal is working

Additional Notes

- The site is built on **WordPress** with **WooCommerce** — both are well-maintained platforms but require regular updates to stay secure. Ensure all plugins, themes, and WordPress core are kept up to date.
- It is recommended to run the site through **Google Safe Browsing** to check whether it has been flagged: <https://transparencyreport.google.com/safe-browsing/search?url=keebforce.com>
- Consider a regular security scan using a tool such as **WPScan**, **Sucuri SiteCheck**, or **Qualys SSL Labs** after the above fixes have been applied.

This report is based on publicly accessible HTTP response headers and HTML source analysis. No intrusive testing was performed.